

INFORME EJECUTIVO: INCIDENTE DE SEGURIDAD "LA MÁS MEJOR S.A."



1. Descripción General del Incidente

El 24 de noviembre de 2025, la Gerencia Financiera reportó la pérdida de fondos en criptoactivos y anomalías en la estación de trabajo del usuario "Vagrant". Tras un análisis, se descarta la hipótesis inicial de un ciberataque de origen estatal ("hackers rusos"). Se confirma que la organización sufrió un ciberataque complejo que combinó técnicas de Ingeniería Social con automatización de malware. Un atacante externo, haciéndose pasar por vendedor de una concesionaria de autos ("BYD"), logró que el Gerente Financiero entregara voluntariamente credenciales de acceso remoto.

2. Principales Hallazgos

- **Origen:** El ataque comenzó con un correo engañoso (Phishing) simulando la venta de un auto, proveniente de un dominio falso (bydargentina-com.biz).
- **Compromiso:** El usuario entregó voluntariamente el control de su equipo al instalar software de acceso remoto (TeamViewer) y facilitar sus credenciales al atacante bajo pretextos de soporte técnico.
- **Impacto Crítico en la Integridad de Datos:** Más allá del intento de robo financiero, se confirma la pérdida de integridad en la base de datos corporativa. El ataque fue exitoso en alterar los registros de Recursos Humanos, modificando

masivamente las direcciones de billeteras de los empleados. Esto representa un compromiso total de la información, no solo un riesgo potencial.

- **Alcance:** El incidente no se limitó a la PC del usuario; el atacante utilizó ese equipo como puente para vulnerar el Servidor de RRHH de la empresa.

3. Causas Probables

La causa raíz es una combinación de factor humano (falta de detección del engaño) y debilidades de seguridad como contraseñas débiles en servidores críticos y falta de segmentación de red que impidiera el salto desde una PC de usuario al servidor.

4. Recomendaciones Prioritarias

1. **Bloqueo Tecnológico:** Prohibir el uso de software de control remoto no corporativo (TeamViewer, AnyDesk) en la red interna.
2. **Restauración:** Recuperar la base de datos de RRHH desde una copia de seguridad anterior al 19 de noviembre de 2025.
3. **Asegurar el dinero:** Mover inmediatamente cualquier fondo que quede a una billetera nueva y segura, ya que las claves actuales las tiene el atacante
4. **Cambio total de contraseñas:** Obligar a todos los usuarios a cambiar sus contraseñas ahora mismo. Esto es urgente para el área de Recursos Humanos y los Administradores, porque confirmamos que el atacante tiene sus claves.

5. Recomendaciones a Mediano Plazo

1. **Activar verificación en dos pasos (MFA):** Implementar el doble factor de autenticación en los sistemas críticos. De esta forma, aunque alguien robe una contraseña, no podrá entrar sin el código del celular.
 2. **Exigir contraseñas difíciles:** Configurar el sistema para que no permita claves fáciles como "pass123". Hay que obligar a usar contraseñas largas y complejas.
 3. **Capacitación al personal:** Dar charlas a los empleados para que entiendan el peligro de guardar claves o frases semilla en archivos de texto en la computadora.
 4. **Controlar lo que se instala:** Restringir los permisos de las computadoras para que los empleados no puedan instalar programas por su cuenta (como pasó con TeamViewer) sin autorización de TI.
-